🛡️ Weekly IT Security Brief (Official-source-first) | 2026-10-18 06:00

Formatted for readability · Auto-generated

📌 Weekly Summary

- Priority snapshot: 5 KEV-listed vulnerabilities are actively exploited in the wild (top 8 shown in this brief).
- Urgent patch focus: CVE-2026-102764(2026-10-19), CVE-2025-61624(2026-10-19), CVE-2026-21589(2026-10-18). Prioritize internet-facing and privileged systems first.
- Threat trend #1: Managing open-weight model risk in enterprise deployments. New whitepaper from Microsoft and NVIDIA helps enterprises manage open-weight AI model risks with a shared taxonomy, evaluations, and controls. The post Managing open-weight model ris...
- Threat trend #2: The hidden network: Inside the phishing infrastructure ecosystem powering global cybercrime. Microsoft uncovered a Chinese-language cybercriminal ecosystem, an interconnected network of phishing kit operators (tracked as Storm-2990), and an i...
- Recommended action this week: patch KEV/high-risk exposed services within 24 hours and tighten monitoring for anomalous login, command execution, and credential access patterns.

🔎 Report A: CVE Deep Dive (CISA KEV + NVD)

CVE-2026-102764

CVE Title	CVE-2026-102764 | beyondtrust/remote_support | Unknown Type
CVE Description	The vulnerability exists within internal components of BeyondTrust's Remote Support product. The components did not adequately validate the origin of the messages it received. Under the right conditions, this could allow an attacker to perform file operations on the appliance.
Root Cause	Use vendor advisories and patch notes for authoritative technical details.
Exploitation Prerequisite	Affected version is reachable through an exploitable path and remains unpatched.
Exploit Path	Attacker leverages public PoC or observed exploit chain for intrusion.
Affected Products	beyondtrust/remote_support
Risk Score	9.8 (CRITICAL)
Exploited in the wild	Listed in CISA KEV
KEV remediation due date	2026-10-19
Mitigation	Apply vendor patches immediately, reduce internet exposure, harden WAF/ACL controls, and enable anomaly detection. Since active exploitation is observed, patch high-risk assets within 24 hours.
Source	https://www.cisa.gov/known-exploited-vulnerabilities-catalog
Source	https://nvd.nist.gov/vuln/detail/CVE-2026-102764

CVE-2025-61624

CVE Title	CVE-2025-61624 | fortinet/fortios | Unknown Type
CVE Description	An Improper Limitation of a Pathname to a Restricted Directory ('Path Traversal') [CWE-22] vulnerability in Fortinet FortiOS 7.6.0 through 7.6.4, FortiOS 7.4.0 through 7.4.9, FortiOS 7.2 all versions, FortiOS 7.0 all versions, FortiOS 6.4 all versions, FortiPAM 1.7.0, FortiPAM 1.6 all versions, FortiPAM 1.5 all versions, FortiPAM 1.4 all versions, FortiPAM 1.3 all versions, FortiPAM 1.2 all versions, Forti...
Root Cause	Use vendor advisories and patch notes for authoritative technical details.
Exploitation Prerequisite	Affected version is reachable through an exploitable path and remains unpatched.
Exploit Path	Attacker leverages public PoC or observed exploit chain for intrusion.
Affected Products	fortinet/fortios, fortinet/fortipam, fortinet/fortiproxy, fortinet/fortiswitchmanager, siemens/ruggedcom_ape1808_firmware
Risk Score	6.0 (MEDIUM)
Exploited in the wild	Listed in CISA KEV
KEV remediation due date	2026-10-19
Mitigation	Apply vendor patches immediately, reduce internet exposure, harden WAF/ACL controls, and enable anomaly detection. Since active exploitation is observed, patch high-risk assets within 24 hours.
Source	https://www.cisa.gov/known-exploited-vulnerabilities-catalog
Source	https://nvd.nist.gov/vuln/detail/CVE-2025-61624

CVE-2026-21589

CVE Title	CVE-2026-21589 | 待核實 | Unknown Type
CVE Description	Rejected reason: This CVE's publication may have been a false positive or a mistake. As a result, we have rejected this record.
Root Cause	Use vendor advisories and patch notes for authoritative technical details.
Exploitation Prerequisite	Affected version is reachable through an exploitable path and remains unpatched.
Exploit Path	Attacker leverages public PoC or observed exploit chain for intrusion.
Affected Products	待核實
Risk Score	待核實 (待核實)
Exploited in the wild	Listed in CISA KEV
KEV remediation due date	2026-10-18
Mitigation	Apply vendor patches immediately, reduce internet exposure, harden WAF/ACL controls, and enable anomaly detection. Since active exploitation is observed, patch high-risk assets within 24 hours.
Source	https://www.cisa.gov/known-exploited-vulnerabilities-catalog
Source	https://nvd.nist.gov/vuln/detail/CVE-2026-21589

CVE-2026-105134

CVE Title	CVE-2026-105134 | ahsay/cloud_backup_suite | Unknown Type
CVE Description	A flaw has been found in Ahsay AhsayCBS up to 10.3.2. This vulnerability affects unknown code of the file /rps/api/json/UpdateReceivers.do of the component Replication Receiver. Executing a manipulation of the argument random can lead to os command injection. It is possible to launch the attack remotely. The exploit has been published and may be used. Upgrading to version 10.3.4 is able to resolve this issue. Upgrad...
Root Cause	Use vendor advisories and patch notes for authoritative technical details.
Exploitation Prerequisite	Affected version is reachable through an exploitable path and remains unpatched.
Exploit Path	Attacker leverages public PoC or observed exploit chain for intrusion.
Affected Products	ahsay/cloud_backup_suite
Risk Score	10.0 (CRITICAL)
Exploited in the wild	Listed in CISA KEV
KEV remediation due date	2026-10-17
Mitigation	Apply vendor patches immediately, reduce internet exposure, harden WAF/ACL controls, and enable anomaly detection. Since active exploitation is observed, patch high-risk assets within 24 hours.
Source	https://www.cisa.gov/known-exploited-vulnerabilities-catalog
Source	https://nvd.nist.gov/vuln/detail/CVE-2026-105134

CVE-2026-76519

CVE Title	CVE-2026-76519 | cisco/asyncos | Unknown Type
CVE Description	A vulnerability in the Advanced Malware Protection (AMP) feature of Cisco Secure Email Gateway could allow an unauthenticated, remote attacker to write arbitrary files on the underlying operating system.
Root Cause	Use vendor advisories and patch notes for authoritative technical details.
Exploitation Prerequisite	Affected version is reachable through an exploitable path and remains unpatched.
Exploit Path	Attacker leverages public PoC or observed exploit chain for intrusion.
Affected Products	cisco/asyncos, cisco/secure_email_gateway_virtual_appliance_c100v, cisco/secure_email_gateway_virtual_appliance_c300v, cisco/secure_email_gateway_virtual_appliance_c600v, cisco/secure_email_gateway_c195
Risk Score	9.8 (CRITICAL)
Exploited in the wild	Listed in CISA KEV
KEV remediation due date	2026-10-17
Mitigation	Apply vendor patches immediately, reduce internet exposure, harden WAF/ACL controls, and enable anomaly detection. Since active exploitation is observed, patch high-risk assets within 24 hours.
Source	https://www.cisa.gov/known-exploited-vulnerabilities-catalog
Source	https://nvd.nist.gov/vuln/detail/CVE-2026-76519

🧪 Report A2: Newly Published CVEs (NVD, last 7 days)

CVE-2026-108605

CVE Title	CVE-2026-108605 | 待核實 | Unknown Type
CVE Description	JeecgBoot through 3.9.5 contains a missing authorization vulnerability in the AiOcrController updateById handler that allows any authenticated user to modify global OCR templates. Low-privileged attackers can send PUT requests to /airag/ocr/edit to overwrite LLM prompts in the shared airag:ocr Redis key, corrupting OCR results for all users.
Affected Products	待核實
Risk Score	4.3 (MEDIUM)
Source	https://nvd.nist.gov/vuln/detail/CVE-2026-108605

CVE-2026-108606

CVE Title	CVE-2026-108606 | 待核實 | Unknown Type
CVE Description	JeecgBoot through 3.9.5 contains a missing authorization vulnerability in the AiOcrController deleteById handler that allows any authenticated user to delete OCR records. Low-privileged attackers can obtain record ids from the unguarded GET /airag/ocr/list endpoint and repeatedly delete every shared OCR prompt record stored in Redis.
Affected Products	待核實
Risk Score	5.4 (MEDIUM)
Source	https://nvd.nist.gov/vuln/detail/CVE-2026-108606

CVE-2026-108607

CVE Title	CVE-2026-108607 | 待核實 | Unknown Type
CVE Description	JeecgBoot through 3.9.5 contains an insecure direct object reference vulnerability that allows authenticated users to delete other users' AI video generation records by supplying arbitrary userId values to DELETE /airag/video/deleteVideoRecord. Attackers can obtain record ids from the unchecked GET /airag/video/listByUser endpoint and delete victims' Redis-stored video history entries one record per reques...
Affected Products	待核實
Risk Score	4.3 (MEDIUM)
Source	https://nvd.nist.gov/vuln/detail/CVE-2026-108607

CVE-2026-108608

CVE Title	CVE-2026-108608 | 待核實 | Unknown Type
CVE Description	JeecgBoot through 3.9.5 contains an insecure direct object reference vulnerability that allows authenticated users to delete other users' AI voice records by supplying an arbitrary userId to DELETE /airag/voice/deleteVoiceRecord. Attackers can obtain record ids from the unchecked GET /airag/voice/listByUser endpoint and delete victims' text-to-speech history entries stored in Redis, one per request.
Affected Products	待核實
Risk Score	4.3 (MEDIUM)
Source	https://nvd.nist.gov/vuln/detail/CVE-2026-108608

Report B: Threat Intelligence News (last 7 days)

Headline: Managing open-weight model risk in enterprise deployments

Source	Microsoft Security Blog
Published	Fri, 16 Oct 2026 16:00:00 +0000
Key Takeaway	New whitepaper from Microsoft and NVIDIA helps enterprises manage open-weight AI model risks with a shared taxonomy, evaluations, and controls. The post Managing open-weight model risk in enterprise deployments appeared first on Microsoft Security Blog . Recommendation: prioritize vulnerable-version inventory, accelerate patching, and monitor anomalous logins/lateral movement.
Summary Engine	extractive-rules
Threat Actors	Not explicitly stated
Target	technology/待核實
Technique	待核實
MITRE ATT&CK	Unverified
Related CVEs	None
Link	https://www.microsoft.com/en-us/security/blog/2026/10/16/managing-open-weight-model-risk-in-enterprise-deployments/

Headline: The hidden network: Inside the phishing infrastructure ecosystem powering global cybercrime

Source	Microsoft Security Blog
Published	Wed, 14 Oct 2026 13:00:00 +0000
Key Takeaway	Microsoft uncovered a Chinese-language cybercriminal ecosystem, an interconnected network of phishing kit operators (tracked as Storm-2990), and an illicit marketplace (tracked as Storm-3119) selling tools and infrastructure for large-scale phishing. The post The hidden network: Inside the phishing Recommendation: prioritize vulnerable-version inventory, accelerate patching, and monitor anomalous logins/lateral move...
Summary Engine	extractive-rules
Threat Actors	Not explicitly stated
Target	ot/global
Technique	Phishing
MITRE ATT&CK	Unverified
Related CVEs	None
Link	https://www.microsoft.com/en-us/security/blog/2026/10/14/the-hidden-network-inside-the-phishing-infrastructure-ecosystem-powering-global-cybercrime/

Headline: CISA, FBI, NSA and International Partners Warn of China-based Cybersecurity Company Enabling Threat Actors to Target Multiple Critical Infr...

Source	CISA News
Published	Thu, 08 Oct 26 12:00:00 +0000
Key Takeaway	CISA, FBI, NSA and International Partners Warn of China-based Cybersecurity Company Enabling Threat Actors to Target Multiple Critical Infrastructure Sectors Worldwide Recommendation: prioritize vulnerable-version inventory, accelerate patching, and monitor anomalous logins/lateral movement.
Summary Engine	extractive-rules
Threat Actors	Not explicitly stated
Target	critical infrastructure/worldwide
Technique	待核實
MITRE ATT&CK	Unverified
Related CVEs	None
Link	https://www.cisa.gov/news-events/news/cisa-fbi-nsa-and-international-partners-warn-china-based-cybersecurity-company-enabling-threat

Headline: CISA Launches Cybersecurity Awareness Month: Securing the Next 250

Source	CISA News
Published	Thu, 01 Oct 26 12:00:00 +0000
Key Takeaway	CISA Launches Cybersecurity Awareness Month: Securing the Next 250 Recommendation: prioritize vulnerable-version inventory, accelerate patching, and monitor anomalous logins/lateral movement.
Summary Engine	extractive-rules
Threat Actors	Not explicitly stated
Target	unknown-target
Technique	待核實
MITRE ATT&CK	Unverified
Related CVEs	None
Link	https://www.cisa.gov/news-events/news/cisa-launches-cybersecurity-awareness-month-securing-next-250

Headline: The Q3 Vulnerability Pulse: Discovery ≠ Exploitation

Source	Cisco Talos Blog
Published	Thu, 15 Oct 2026 18:00:00 GMT
Key Takeaway	Is the cybersecurity world really facing a "Bugmageddon?" Thor breaks down the latest CVE and KEV trends in the latest Threat Source newsletter. Recommendation: prioritize vulnerable-version inventory, accelerate patching, and monitor anomalous logins/lateral movement.
Summary Engine	extractive-rules
Threat Actors	Not explicitly stated
Target	unknown-target
Technique	Exploit Chain
MITRE ATT&CK	Unverified
Related CVEs	None
Link	https://blog.talosintelligence.com/the-q3-vulnerability-pulse-discovery-exploitation/

Headline: Break the silence: Kazakhstan-nexus UAT-6275 targets CIS government organizations

Source	Cisco Talos Blog
Published	Wed, 14 Oct 2026 14:00:00 GMT
Key Takeaway	Talos and Recorded Future identified UAT-6275 activity targeting government organizations across the Commonwealth of Independent States. Recovered artifacts show additional interest in water resources and energy. Recommendation: prioritize vulnerable-version inventory, accelerate patching, and monitor anomalous logins/lateral movement.
Summary Engine	extractive-rules
Threat Actors	Not explicitly stated
Target	government/待核實
Technique	待核實
MITRE ATT&CK	Unverified
Related CVEs	None
Link	https://blog.talosintelligence.com/break-the-silence-kazakhstan-nexus-uat-6275-targets-cis-government-organizations/

Headline: MALFEX npm Package 'imgdecode' Hides Shellcode Loader in Windows Native Addon

Source	The Hacker News
Published	Sat, 17 Oct 2026 16:41:56 +0530
Key Takeaway	Cybersecurity researchers have discovered a malicious npm package that's part of a recently disclosed software supply chain attack campaign dubbed MALFEX. The package, named "imgdecode," was uploaded to the package registry on September 30, 2026, by a user named "malfexteste8." It has been downloade Recommendation: prioritize vulnerable-version inventory, accelerate patching, and monitor ano...
Summary Engine	extractive-rules
Threat Actors	Not explicitly stated
Target	technology/待核實
Technique	待核實
MITRE ATT&CK	Unverified
Related CVEs	None
Link	https://thehackernews.com/2026/10/malfex-npm-package-imgdecode-hides.html

Headline: Hackers Use Compromised ConnectWise Credential to Sign In to 173 Microsoft 365 Tenants

Source	The Hacker News
Published	Sat, 17 Oct 2026 11:46:46 +0530
Key Takeaway	Cybersecurity researchers are sounding the alarm related to an active campaign in which unknown threat actors are abusing a compromised Microsoft 365 (M365) credential belonging to ConnectWise Cloud Backup (formerly SkyKick) to gain unauthorized access to customers' M365 environments. ConnectWise Cl Recommendation: prioritize vulnerable-version inventory, accelerate patching, and monitor anomalous logins/latera...
Summary Engine	extractive-rules
Threat Actors	Not explicitly stated
Target	cloud/待核實
Technique	Credential Access
MITRE ATT&CK	Unverified
Related CVEs	None
Link	https://thehackernews.com/2026/10/hackers-use-compromised-connectwise.html

Headline: Israeli Ad Firm Doubled as Candiru’s Zero-Click Spyware Delivery Channel

Source	SecurityWeek
Published	Sat, 17 Oct 2026 11:00:00 +0000
Key Takeaway	Israeli company Discover-Tech’s ads allow threat actors to fingerprint and track devices at scale and infect selected targets. The post Israeli Ad Firm Doubled as Candiru’s Zero-Click Spyware Delivery Channel appeared first on SecurityWeek . Recommendation: prioritize vulnerable-version inventory, accelerate patching, and monitor anomalous logins/lateral movement.
Summary Engine	extractive-rules
Threat Actors	Not explicitly stated
Target	unknown-target
Technique	待核實
MITRE ATT&CK	Unverified
Related CVEs	None
Link	https://www.securityweek.com/israeli-ad-firm-doubled-as-candirus-zero-click-spyware-delivery-channel/

Headline: In Other News: ICS-Sniper Attack, Hacking XWorm Malware Operators, $250k Chrome Exploit

Source	SecurityWeek
Published	Fri, 16 Oct 2026 14:09:51 +0000
Key Takeaway	The post In Other News: ICS-Sniper Attack, Hacking XWorm Malware Operators, $250k Chrome Exploit appeared first on SecurityWeek . Recommendation: prioritize vulnerable-version inventory, accelerate patching, and monitor anomalous logins/lateral movement.
Summary Engine	extractive-rules
Threat Actors	Not explicitly stated
Target	ot/待核實
Technique	Malware Deployment
MITRE ATT&CK	Unverified
Related CVEs	None
Link	https://www.securityweek.com/in-other-news-ics-sniper-attack-hacking-xworm-malware-operators-250k-chrome-exploit/

Headline: Hackers breach Microsoft 365 tenants via ConnectWise supply-chain attack

Source	BleepingComputer
Published	Sat, 17 Oct 2026 11:18:51 -0400
Key Takeaway	ConnectWise has shut down customer access to its Cloud Backup service (formerly SkyKick Cloud Backup) after hackers accessed application identities and compromised Microsoft 365 tenants. [...] Recommendation: prioritize vulnerable-version inventory, accelerate patching, and monitor anomalous logins/lateral movement.
Summary Engine	extractive-rules
Threat Actors	Not explicitly stated
Target	cloud/待核實
Technique	待核實
MITRE ATT&CK	Unverified
Related CVEs	None
Link	https://www.bleepingcomputer.com/news/security/hackers-breach-microsoft-365-tenants-via-connectwise-supply-chain-attack/

Headline: Drupal patches critical RCE flaws, warns exploits may emerge soon

Source	BleepingComputer
Published	Sat, 17 Oct 2026 10:32:48 -0400
Key Takeaway	Drupal has patched two critical vulnerabilities that could allow attackers to execute code remotely on websites running any supported version of the content management system. [...] Recommendation: prioritize vulnerable-version inventory, accelerate patching, and monitor anomalous logins/lateral movement.
Summary Engine	extractive-rules
Threat Actors	Not explicitly stated
Target	ot/待核實
Technique	Exploit Chain
MITRE ATT&CK	Unverified
Related CVEs	None
Link	https://www.bleepingcomputer.com/news/security/drupal-patches-critical-rce-flaws-warns-exploits-may-emerge-soon/

📚 Sources (official/authoritative first)

https://www.cisa.gov/known-exploited-vulnerabilities-catalog

https://nvd.nist.gov/

https://www.cve.org/

https://attack.mitre.org/

https://www.microsoft.com/en-us/security/blog/

https://www.cisa.gov/news-events/cybersecurity-advisories

https://www.mandiant.com/resources

https://blog.talosintelligence.com/